

UNIVERSIDAD MAYOR DE SAN ANDRÉS
FACULTAD DE CIENCIAS PURAS Y NATURALES
CARRERA DE INFORMÁTICA



PERFIL DE TESIS DE GRADO

**ALGORITMO ADAPTATIVO PARA LA RECALIBRACIÓN
DINÁMICA DEL RIESGO DE EXPOSICIÓN Y COMPROMISO EN
SERVICIOS DE INFRAESTRUCTURA LINUX MEDIANTE
VERIFICACIÓN TÉCNICA CONTROLADA**

Tesis de Grado para obtener el Título de Licenciatura en Informática

Mención Ingeniería de Sistemas Informáticos

POR: CLAUDIO ANDRÉS SANJINES CUÉLLAR

TUTOR: M.Sc. ALDO VALDEZ ALVARADO

LA PAZ – BOLIVIA

Julio, 2026

ÍNDICE

1. INTRODUCCIÓN.....	1
2. ANTECEDENTES.....	2
2.1. PENTESTING AUTOMATIZADO Y ADAPTATIVO.....	2
2.2. EVALUACIÓN DINÁMICA DEL RIESGO CIBERNÉTICO.....	4
2.3. ANTECEDENTES EN EL CONTEXTO LATINOAMERICANO Y NACIONAL.....	7
2.4. SÍNTESIS Y BRECHA DE INVESTIGACIÓN.....	9
3. PLANTEAMIENTO DEL PROBLEMA.....	11
3.1. PROBLEMA CENTRAL.....	12
3.2. PROBLEMAS SECUNDARIOS.....	12
4. OBJETIVOS.....	13
4.1. OBJETIVO GENERAL.....	13
4.2. OBJETIVOS ESPECÍFICOS.....	13
5. HIPÓTESIS.....	14
5.1. OPERACIONALIZACIÓN DE VARIABLES.....	14
6. JUSTIFICACIÓN.....	17
6.1. JUSTIFICACIÓN ECONÓMICA.....	18
6.2. JUSTIFICACIÓN SOCIAL.....	19
6.3. JUSTIFICACIÓN CIENTÍFICA.....	20
7. ALCANCES Y LÍMITES.....	21
7.1. ALCANCES.....	21
7.2. LÍMITES.....	23
8. APORTES.....	24
8.1. APORTE TEÓRICO.....	24
8.2. APORTE PRÁCTICO.....	25
9. METODOLOGÍA.....	26
9.1. METODOLOGÍA DE INVESTIGACIÓN.....	27
9.2. METODOLOGÍA DE DESARROLLO DE INGENIERÍA.....	29
10. MARCO TEÓRICO.....	32
11. ÍNDICE TENTATIVO.....	37
12. CRONOGRAMA DE AVANCE.....	45
13. BIBLIOGRAFÍA.....	46
ANEXOS.....	50

1. INTRODUCCIÓN

En el ámbito de la seguridad informática, las infraestructuras basadas en Linux sostienen servicios relevantes para la administración y operación tecnológica de una organización. Servicios como SSH, FTP y SMB permiten la administración remota, la transferencia de archivos y la compartición de recursos en red; sin embargo, al exponerse bajo configuraciones débiles, incrementan el riesgo de compromiso del sistema.

La evaluación de riesgos en ciberseguridad se apoya en criterios definidos, como exposición, probabilidad de explotación, impacto y criticidad. Estos modelos permiten clasificar y priorizar riesgos potenciales; no obstante, resultan limitados cuando no se contrastan con condiciones técnicas verificables, debido a que el riesgo se modifica durante el proceso de validación (Cheimonidis y Rantos, 2023).

En este contexto, las pruebas de seguridad y el pentesting controlado permiten obtener evidencia técnica sobre el estado real de un servicio dentro de un entorno específico (Abu-Dabaseh y Alshammari, 2018). Sin embargo, en la práctica estos resultados suelen presentarse como hallazgos separados del proceso formal de evaluación, lo que dificulta ajustar el riesgo con base en la evidencia obtenida mediante verificación técnica controlada.

A partir de esta brecha, la presente investigación plantea el diseño de un algoritmo adaptativo denominado ARDREC (Algoritmo de Recalibración Dinámica del Riesgo de Exposición y Compromiso), orientado a la recalibración dinámica del riesgo en servicios de infraestructura Linux. La propuesta integra riesgo inicial, evidencia técnica acumulada y criticidad contextual para producir una estimación final ajustada y contrastable.

Finalmente, la investigación busca aportar un modelo medible y reproducible que fortalezca la relación entre evaluación estática del riesgo y validación dinámica basada en evidencia.

2. ANTECEDENTES

En los últimos años, la ciberseguridad ha evolucionado desde enfoques principalmente preventivos y estáticos hacia mecanismos dinámicos, automatizados y sustentados en evidencia técnica. Esta evolución se observa en dos líneas de investigación relevantes: el pentesting automatizado y adaptativo, orientado a mejorar la planificación, ejecución y trazabilidad de pruebas de seguridad; y la evaluación dinámica del riesgo cibernético, centrada en ajustar la valoración del riesgo a partir de información cambiante, dependencias entre activos, probabilidad de explotación y contexto organizacional. La revisión de ambas líneas permite comprender el estado actual de la investigación y evidencia la necesidad de integrar la validación técnica de vulnerabilidades con modelos formales de estimación del riesgo.

2.1. PENTESTING AUTOMATIZADO Y ADAPTATIVO

En la línea del pentesting automatizado, Ghanem (2022), mediante el trabajo “Towards an Efficient Automation of Network Penetration Testing Using Model-Based Reinforcement Learning”, propuso el framework IAPTF, basado en aprendizaje por refuerzo, POMDP y una base de conocimiento para apoyar la toma de decisiones durante pruebas de penetración. Su investigación aborda la dificultad de ejecutar pentesting manual en redes medianas y grandes, debido a que estas pruebas pueden ser repetitivas, complejas y costosas. El trabajo destaca por representar el pentesting como un problema de decisión secuencial, permitiendo seleccionar acciones de prueba de manera más eficiente y reutilizar conocimiento en procesos posteriores de evaluación.

Hung y Cong (2023), en “Applying Reinforcement Learning in Automated Penetration Testing”, aplicaron aprendizaje por refuerzo y grafos de ataque para automatizar la selección de rutas dentro de procesos de pentesting. La propuesta modela el entorno de evaluación mediante caminos de ataque y utiliza algoritmos de aprendizaje para identificar acciones óptimas frente a distintos escenarios. Este estudio aporta una

perspectiva algorítmica relevante para la planificación de pruebas ofensivas controladas, especialmente en la búsqueda de rutas de explotación dentro de sistemas de red.

Hance, Milbrath, Ross y Straub (2022), en “Distributed Attack Deployment Capability for Modern Automated Penetration Testing”, presentaron una capacidad distribuida para pruebas de penetración automatizadas, orientada a simular ataques complejos sobre infraestructuras modernas. La propuesta permite coordinar nodos distribuidos para ejecutar pruebas de seguridad de forma más rápida y autónoma, ampliando el alcance de la automatización hacia entornos donde una sola instancia de evaluación puede resultar insuficiente. Su contribución se centra en la ejecución coordinada de pruebas y en la simulación de escenarios ofensivos de mayor complejidad.

Alhamed y Rahman (2023), en “A Systematic Literature Review on Penetration Testing in Networks: Future Research Directions”, realizaron una revisión sistemática sobre pentesting en redes, vulnerabilidades, herramientas, puertos expuestos y líneas futuras de investigación. El estudio identifica la automatización del pentesting y el uso de aprendizaje automático como áreas relevantes para mejorar la eficiencia de las pruebas, reducir tiempos de evaluación y fortalecer la detección de vulnerabilidades. Al tratarse de una revisión sistemática, su valor principal se encuentra en la organización del conocimiento existente y en la identificación de tendencias futuras dentro del pentesting en redes.

Skandylas y Asplund (2025), en “Automated Penetration Testing: Formalization and Realization”, formalizaron el problema del pentesting automatizado y presentaron la herramienta ADAPT, validada en entornos como Metasploitable2, Metasploitable3 y una red virtual. El trabajo propone una arquitectura de automatización capaz de operar sobre hosts y servicios, incorporando razonamiento en tiempo de ejecución para seleccionar acciones durante el proceso de prueba. Esta investigación resulta relevante porque traslada la automatización del pentesting desde modelos abstractos hacia entornos prácticos de laboratorio con servicios reales.

Raza (2024), en “Systematic Literature Review of Challenges and AI Contributions in Penetration Testing”, revisó los aportes de la inteligencia artificial al pentesting, destacando su potencial para mejorar la automatización, efectividad y flexibilidad en la evaluación de vulnerabilidades. El estudio también identifica desafíos relacionados con la calidad de los datos, ataques adversariales, consideraciones éticas y la necesidad de combinar automatización con criterio humano. Este antecedente muestra que la inteligencia artificial puede fortalecer distintas fases del pentesting, aunque su aplicación requiere control metodológico, trazabilidad y validación cuidadosa.

Lazarov, Seda, Martinasek y Kummel (2025), en “Penterep: Comprehensive Penetration Testing with Adaptable Interactive Checklists”, propusieron un entorno de pentesting basado en listas interactivas adaptables, combinando pruebas manuales y automatizadas, bases de conocimiento, metodologías como PTES, OWASP y NIST, y generación de reportes. El estudio resalta que las herramientas completamente automatizadas pueden ser insuficientes para identificar todas las vulnerabilidades, por lo que resulta necesario integrar automatización, guía metodológica y verificación manual. El trabajo fortalece la importancia de la trazabilidad, completitud y control del proceso de pentesting.

2.2. EVALUACIÓN DINÁMICA DEL RIESGO CIBERNÉTICO

En la línea de evaluación dinámica de riesgos, Behbehani, Komninos, Al-Begain y Rajarajan (2023), mediante el modelo “Cloud Enterprise Dynamic Risk Assessment”, propusieron una evaluación dinámica de riesgo para entornos cloud, utilizando CVSS, inteligencia de amenazas, disponibilidad de exploits y redes bayesianas dinámicas. El modelo permite actualizar estimaciones de riesgo conforme se incorpora nueva información, además de proyectar pérdidas financieras asociadas a incidentes de seguridad. Su aporte se encuentra en el uso de redes bayesianas dinámicas para tratar la incertidumbre y variabilidad del riesgo en infraestructuras cloud.

Cheimonidis y Rantos (2023), en “Dynamic Risk Assessment in Cybersecurity: A Systematic Literature Review”, revisaron modelos de evaluación dinámica de riesgo en

ciberseguridad y señalaron que las metodologías tradicionales presentan dificultades para adaptarse a entornos modernos donde las amenazas cambian rápidamente y aparecen nuevas vulnerabilidades. El estudio organiza los enfoques existentes según métodos de análisis, dominios de aplicación, tipos de entrada y nivel de madurez. Su contribución consiste en evidenciar la transición de modelos estáticos hacia enfoques dinámicos capaces de incorporar información cambiante en la evaluación del riesgo.

Cheimonidis y Rantos (2025a), en “A Novel Proactive and Dynamic Cyber Risk Assessment Methodology”, propusieron una metodología dinámica y proactiva que integra información interna, fuentes abiertas, EPSS y redes bayesianas para estimar probabilidad de ataque e impacto. La propuesta transforma datos cualitativos y cuantitativos en valores numéricos que alimentan un modelo probabilístico, permitiendo estimar el riesgo en un entorno SCADA. El estudio destaca por combinar información del contexto organizacional con fuentes externas de ciberseguridad para generar estimaciones dinámicas y proactivas.

Posteriormente, Cheimonidis y Rantos (2025b), en “A Proactive and Time-Sensitive Cyber Risk Assessment Model Integrating Markov Chains and Bayesian Networks”, plantearon un modelo dinámico, proactivo y sensible al tiempo que utiliza EPSS para estimar la probabilidad de explotación en una ventana temporal de treinta días, redes bayesianas para representar dependencias entre activos, grafos de ataque y cadenas de Markov absorbentes. El modelo permite analizar cómo evoluciona la probabilidad de compromiso durante un periodo determinado y estimar el tiempo requerido para que un atacante avance entre activos. Esta investigación amplía la evaluación dinámica hacia una perspectiva temporal del riesgo.

Phillips, Taylor, Boniface, Modafferi y Surridge (2024), en “Automated Knowledge-Based Cybersecurity Risk Assessment of Cyber-Physical Systems”, propusieron una evaluación automatizada de riesgo basada en conocimiento para sistemas ciberfísicos, utilizando modelado causa-efecto, rutas de ataque, controles de

seguridad y simulación mediante Spyderisk. El enfoque permite identificar amenazas relevantes, calcular niveles de riesgo y representar dependencias complejas entre activos. Su contribución se encuentra en la automatización del análisis de riesgo mediante una base de conocimiento reutilizable y explicable, especialmente útil en sistemas ciberfísicos complejos.

Islam, Basheer, Papastergiou, Ciampi y Silvestri (2025), en “Intelligent Dynamic Cybersecurity Risk Management Framework with Explainability and Interpretability of AI Models for Enhancing Security and Resilience of Digital Infrastructure”, propusieron un framework dinámico de gestión de riesgos que integra explotación de vulnerabilidades, dependencias entre activos, regresión lineal, deep learning, explicabilidad e interpretabilidad. El modelo utiliza datos de vulnerabilidades para priorizar riesgos y explicar las decisiones del sistema mediante técnicas de inteligencia artificial explicable. Este antecedente aporta una visión orientada a fortalecer la confianza en los modelos de riesgo dinámico mediante resultados interpretables y justificables.

Chitraju (2025), en “The Adaptive Data-Driven Threat Scoring for Enhanced Cybersecurity Risk Assessment”, propuso un sistema adaptativo de puntuación de amenazas basado en datos, integrando telemetría de red, señales de endpoint, comportamiento de usuarios e inteligencia de amenazas para cuantificar el riesgo casi en tiempo real. La propuesta emplea ingeniería de características, modelado probabilístico, reglas adaptativas y retroalimentación continua para ajustar las puntuaciones cuando aparece nueva evidencia. El estudio incorpora múltiples fuentes de datos operativos para actualizar la valoración del riesgo de acuerdo con el comportamiento observado del entorno.

Renney, Chenchiah, Nethercott, Paligadu y Lang (2025), en “An Open and Adaptable Approach to Vulnerability Risk Scoring”, propusieron un enfoque abierto y adaptable para priorizar vulnerabilidades mediante un sistema de dos capas: una global para

calcular el riesgo por CVE y una local que enriquece el riesgo según el contexto organizacional. A partir de este enfoque desarrollaron V-Score, orientado a mejorar la identificación de vulnerabilidades de alto riesgo frente al uso exclusivo de CVSS. El trabajo cuestiona la dependencia de puntuaciones generales y resalta la importancia de incorporar adaptabilidad y contexto local dentro del proceso de puntuación de vulnerabilidades.

2.3. ANTECEDENTES EN EL CONTEXTO LATINOAMERICANO Y NACIONAL

En el ámbito latinoamericano, los trabajos revisados muestran que el pentesting se ha aplicado principalmente como procedimiento de diagnóstico, auditoría o generación de recomendaciones de seguridad. Alonso y Antolínez (2022), en “Análisis de vulnerabilidades a un segmento de la red privada del área de TI de una empresa del sector industrial basado en la metodología PTES”, realizaron un análisis de vulnerabilidades en una red privada utilizando herramientas de evaluación de seguridad y siguiendo fases metodológicas de pentesting. El trabajo incluyó definición de alcance, identificación de activos, autorización de pruebas, ejecución técnica y elaboración de un plan de remediación. Su aporte se centra en la aplicación estructurada de PTES para evaluar una red empresarial y proponer acciones correctivas.

Barrios (2024), en “Análisis e Implementación de las Fases del Pentesting Detectando Vulnerabilidades en un Sistema Informático Remoto”, documentó la aplicación de fases de pentesting en un entorno remoto de laboratorio, empleando herramientas de reconocimiento, análisis de tráfico y explotación controlada. El estudio resalta la importancia de seguir etapas definidas para lograr mayor efectividad en la detección de vulnerabilidades y en la propuesta de medidas de defensa. Esta investigación aporta una aplicación práctica de una secuencia metodológica para ejecutar pruebas de penetración controladas.

Sierra y Rincón (2024), en “Guía Integral de Ciberseguridad y Pentesting para Proteger Activos Digitales y Detectar Vulnerabilidades”, elaboraron una guía orientada a identificar y corregir vulnerabilidades web con base en OWASP Top 10, WebGoat y WebWolf. La propuesta presenta directrices prácticas para la gestión de vulnerabilidades, mitigación de riesgos y protección de activos digitales. Su enfoque se dirige principalmente al fortalecimiento de aplicaciones web mediante pruebas guiadas y recomendaciones de seguridad.

Cachaya, Castañeda, Torres y Pérez (2025), en “Sandbox Virtual con Herramientas Open Source para Pentesting: Una Propuesta Tecnológica Aplicada a la Seguridad Cibernética de las PYMEs”, diseñaron e implementaron una arquitectura de sandbox virtual con herramientas open source orientada a identificar vulnerabilidades en aplicaciones móviles y sitios web de pequeñas y medianas empresas. El trabajo aporta un entorno controlado y replicable para ejecutar pruebas de seguridad, facilitando el acceso de las PYMEs a procesos de análisis técnico.

En el contexto nacional e institucional, los antecedentes revisados permiten observar cómo la investigación en seguridad informática dentro de la Universidad Mayor de San Andrés ha abordado principalmente modelos de seguridad, evaluación de aplicaciones web, gestión de riesgos y detección de intrusos. Callisaya (2023), en “Modelo de Evaluación de Seguridad para Aplicaciones Web basado en OWASP”, propuso un modelo de evaluación de seguridad para aplicaciones web basado en OWASP, incorporando identificación de alcance, recopilación de información, revisión de código, pruebas de caja negra y caja blanca, CVSS, reporte de vulnerabilidades y priorización. Su aporte consiste en articular evaluación técnica, clasificación de vulnerabilidades y valoración de riesgo dentro del dominio de aplicaciones web.

Luna (2023), en “Modelo de Prevención de Intrusos en la Red con Machine Learning”, desarrolló un modelo basado en algoritmos de aprendizaje automático para detectar tráfico malicioso y prevenir intrusiones. La investigación evaluó árboles de decisión,

bosques de decisión y redes neuronales supervisadas, concluyendo que Random Forest presentó mejor desempeño durante el entrenamiento del modelo. Este antecedente se ubica en la aplicación de técnicas inteligentes para la detección y prevención de intrusiones en redes.

Chambi (2024), en “Modelo de Gestión de Seguridad para minimizar Riesgos de Seguridad Informática en empresas del Sector Automotriz”, propuso un modelo basado en ISO/IEC 27001, ISO/IEC 27002, NIST 800-61 y buenas prácticas para minimizar riesgos de seguridad informática. La investigación incluyó diagnóstico, valoración de madurez, diseño de controles, políticas, procedimientos, validación por expertos e implementación en una empresa del sector automotriz. Su contribución se orienta a la gestión organizacional de la seguridad y a la reducción de riesgos mediante controles, políticas y procedimientos.

2.4. SÍNTESIS Y BRECHA DE INVESTIGACIÓN

A partir de los antecedentes revisados, se observa que la investigación sobre pentesting automatizado ha avanzado en la planificación de acciones, automatización de pruebas, uso de aprendizaje por refuerzo, ejecución distribuida, herramientas de apoyo, listas interactivas y entornos de laboratorio. Estos trabajos fortalecen la eficiencia, trazabilidad y cobertura de las pruebas de seguridad. No obstante, su énfasis principal se encuentra en la ejecución, organización o automatización del proceso de pentesting, más que en la conversión formal de los resultados técnicos en una recalibración dinámica del riesgo.

De forma paralela, los modelos de evaluación dinámica del riesgo han incorporado fuentes y técnicas como CVSS, EPSS, inteligencia de amenazas, redes bayesianas, cadenas de Markov, aprendizaje automático, criticidad de activos y contexto organizacional. Behbehani et al. (2023) integran CVSS, inteligencia de amenazas, disponibilidad de exploits y redes bayesianas dinámicas para actualizar estimaciones de riesgo en entornos cloud. Cheimonidis y Rantos (2025b) incorporan EPSS, redes bayesianas, grafos de ataque y cadenas de Markov para representar la evolución

temporal del riesgo. Islam et al. (2025) integran explotación de vulnerabilidades, dependencias entre activos y modelos de inteligencia artificial explicable para fortalecer la priorización e interpretación del riesgo. Estos enfoques permiten actualizar la valoración del riesgo con información variable, modelar dependencias entre activos y estimar probabilidades de explotación. Sin embargo, gran parte de estos modelos se apoya en datos externos, históricos, probabilísticos u operativos, sin integrar de manera directa la evidencia obtenida mediante verificación técnica controlada sobre servicios específicos de infraestructura Linux.

En el contexto latinoamericano y nacional, los antecedentes muestran una orientación predominante hacia diagnósticos de vulnerabilidades, aplicación de metodologías de pentesting, evaluación de aplicaciones web, guías de seguridad, modelos de gestión y detección de intrusos. Estos trabajos aportan procedimientos, herramientas y buenas prácticas para mejorar la seguridad informática; no obstante, se identifica una brecha en el desarrollo de modelos algorítmicos que integren pentesting controlado, evidencia técnica cuantificable y evaluación dinámica del riesgo en servicios de infraestructura Linux.

Frente a esta brecha, ARDREC se posiciona como una propuesta ubicada en la intersección entre pentesting automatizado y evaluación dinámica del riesgo cibernético. Su aporte consiste en transformar la evidencia obtenida mediante verificación técnica controlada en servicios SSH, FTP y SMB en un insumo formal para recalibrar dinámicamente el riesgo de exposición y compromiso. Esta integración permite que los resultados técnicos no queden aislados como simples hallazgos, sino que formen parte directa del cálculo del riesgo. Además, fortalece la trazabilidad entre la condición observada del servicio y el valor final asignado por el modelo. De esta manera, el algoritmo integra riesgo inicial, evidencia técnica acumulada, criticidad contextual y riesgo final recalibrado dentro de un modelo algorítmico medible, explicable y reproducible, orientado a reducir la diferencia entre el riesgo estimado y el riesgo verificado experimentalmente.

3. PLANTEAMIENTO DEL PROBLEMA

La evaluación de riesgos en infraestructuras tecnológicas relaciona activos, amenazas, vulnerabilidades, probabilidad e impacto para determinar un nivel inicial de riesgo (International Organization for Standardization/International Electrotechnical Commission [ISO/IEC], 2018). National Institute of Standards and Technology (NIST, 2012) señala que esta valoración debe considerar las condiciones que afectan al sistema evaluado. Sin embargo, los modelos estáticos presentan dificultades para adaptarse a entornos donde las amenazas, vulnerabilidades y condiciones operativas cambian con el tiempo (Cheimonidis y Rantos, 2023). En consecuencia, una valoración que no se actualiza con información obtenida durante la evaluación puede conservar un nivel de riesgo que ya no representa adecuadamente las condiciones técnicas del servicio analizado (Cheimonidis y Rantos, 2023).

Las pruebas técnicas de seguridad permiten obtener evidencia verificable mediante descubrimiento de red, escaneo de puertos, identificación de vulnerabilidades y validación controlada de debilidades (NIST, 2008). PCI Security Standards Council (PCI SSC, 2017) establece que las pruebas de penetración requieren un alcance definido, reglas de compromiso, ejecución controlada y reporte de resultados. Además, la evidencia obtenida debe registrarse de manera trazable para relacionar cada hallazgo con la condición técnica que lo produjo (NIST, 2008). No obstante, estos resultados suelen presentarse como hallazgos técnicos sin integrarse formalmente en el cálculo dinámico del riesgo.

Los servicios SSH, FTP y SMB permiten realizar funciones de administración remota, transferencia de archivos y compartición de recursos. SSH proporciona mecanismos de comunicación y administración remota segura (Ylönen y Lonvick, 2006). FTP permite transferir archivos mediante una arquitectura cliente-servidor (Postel y Reynolds, 1985). SMB posibilita compartir archivos y otros recursos dentro de una infraestructura de red (Terpstra y Vernooij, 2005). La ausencia de integración entre estos hallazgos y la

evaluación inicial dificulta ajustar el riesgo según el estado técnico observado. Por ello, se requiere un mecanismo que integre el riesgo inicial, la evidencia técnica acumulada y la criticidad contextual para recalibrar el riesgo conforme se incorporan condiciones verificables (Cheimonidis y Rantos, 2023).

3.1. PROBLEMA CENTRAL

¿Cómo recalibrar dinámicamente el riesgo de exposición y compromiso en servicios de infraestructura Linux?

3.2. PROBLEMAS SECUNDARIOS

A partir del problema central planteado, se identifican los siguientes problemas secundarios:

- La dependencia de criterios estáticos de exposición, probabilidad de explotación e impacto en la evaluación inicial ocasiona que el riesgo calculado para servicios SSH, FTP y SMB, pueda quedar sobreestimado, subestimado o desconectado del estado técnico real del servicio evaluado.
- La presentación de resultados de pentesting como hallazgos aislados o cualitativos, dificulta su conversión en evidencia técnica estructurada, observable y cuantificable para valorar el riesgo.
- La falta de integración algorítmica entre la evidencia obtenida durante pruebas controladas y el proceso formal de evaluación de riesgos, limita la recalibración dinámica del nivel de riesgo según las condiciones verificadas.
- La selección secuencial o predefinida de pruebas técnicas, sin considerar el estado dinámico del servicio evaluado, dificulta priorizar adaptativamente la ejecución de validaciones según el riesgo inicial, la evidencia acumulada y la criticidad contextual.

- La evaluación basada únicamente en estimaciones estáticas dificulta medir con precisión el error de estimación y valorar formalmente la efectividad de un enfoque dinámico frente a múltiples escenarios técnicos independientes.

4. OBJETIVOS

4.1. OBJETIVO GENERAL

Diseñar un algoritmo adaptativo que permita recalibrar dinámicamente el riesgo de exposición y compromiso para servicios de infraestructura Linux.

4.2. OBJETIVOS ESPECÍFICOS

El presente trabajo de investigación tiene como objetivos específicos los siguientes:

- Representar formalmente el riesgo inicial de exposición y compromiso en servicios SSH, FTP y SMB de infraestructura Linux mediante un modelo algorítmico y matemático.
- Definir dimensiones observables, medibles y cuantificables de evidencia técnica acumulada para la evaluación del riesgo durante pruebas controladas de pentesting.
- Formular una función de recalibración dinámica del riesgo que integre el riesgo inicial, la evidencia técnica acumulada y la criticidad contextual de cada servicio dentro del modelo ARDREC.
- Establecer un mecanismo adaptativo de priorización que oriente la selección de pruebas técnicas en función del riesgo inicial, la evidencia técnica acumulada y la criticidad contextual de cada servicio.
- Evaluar experimentalmente la efectividad del algoritmo ARDREC en comparación con un modelo estático de evaluación de riesgo, mediante indicadores de precisión, variación del riesgo estimado y correspondencia con la evidencia técnica observada en múltiples escenarios técnicos independientes.

5. HIPÓTESIS

La aplicación de un algoritmo adaptativo en servicios de infraestructura Linux, basado en la comparación entre estimaciones generadas por modelos de evaluación estática y condiciones técnicas verificables, permite recalibrar dinámicamente el riesgo de exposición y compromiso, reduciendo el error entre los valores calculados inicialmente y los validados experimentalmente.

5.1. OPERACIONALIZACIÓN DE VARIABLES

La operacionalización de variables se realizará considerando como infraestructura observada los servicios SSH, FTP y SMB en un entorno Linux controlado. Estos servicios serán evaluados mediante escenarios experimentales definidos, en los cuales se comparará un método estático de estimación del riesgo con el algoritmo adaptativo ARDREC. La finalidad de esta operacionalización es establecer la relación entre el método de cálculo aplicado, la precisión de la estimación del riesgo, las condiciones técnicas y contextuales del servicio evaluado, y los elementos de control necesarios para mantener la comparabilidad entre escenarios.

Asimismo, permitirá convertir los conceptos principales de la investigación en indicadores observables y medibles, registrables durante la ejecución experimental. De esta manera, el riesgo podrá ser analizado como un valor cuantificable y contrastado con la evidencia técnica obtenida en laboratorio.

Como se observa en la tabla 1, la investigación considera una variable independiente, una variable dependiente, una variable interviniente y dos variables de control. Las variables cuantificables serán expresadas mediante escalas numéricas, rangos normalizados o valores categóricos codificados, con el propósito de permitir su registro, comparación y análisis estadístico.

Tabla 1. *Operacionalización de variables principales*

Tipo de variable	Variable	Definición operacional	Escala / rango
Independiente	Método de cálculo y recalibración del riesgo	Se operacionaliza mediante la comparación entre dos métodos de estimación del riesgo: el método estático inicial y el método dinámico adaptativo basado en ARDREC.	Escala nominal dicotómica: 0 = método estático 1 = método dinámico adaptativo ARDREC.
Dependiente	Precisión de la estimación del riesgo	Se medirá mediante la cercanía entre el riesgo calculado por cada método y el criterio externo de referencia experimental, utilizando el error absoluto y el error absoluto medio. El error absoluto se expresará como: $EA_i = Rref_i - Rcalc_i $.	Escala continua normalizada de 0.00 a 1.00, equivalente a 0 % – 100 %. Se espera que $MAE_{(ARDREC)} < MAE_{(estático)}$

Interviniente	Condiciones técnicas y contextuales del servicio evaluado	Se considerarán los factores que pueden influir en la estimación del riesgo y en la evidencia obtenida durante la validación, tales como exposición, probabilidad de explotación, impacto potencial, evidencia técnica acumulada y criticidad contextual.	Exposición, probabilidad e impacto: escala ordinal de 1 a 5. Evidencia técnica acumulada: escala normalizada de 0.00 a 1.00. Criticidad contextual: escala ordinal de 1 a 5, normalizable al intervalo [0,1].
Control	Servicios evaluados	La investigación se delimitará a los servicios SSH, FTP y SMB como infraestructura observada dentro de un entorno Linux controlado.	Escala nominal: SSH, FTP y SMB. Muestra mínima: 45 observaciones, distribuidas en 15 escenarios por servicio.
Control	Entorno experimental	Las pruebas se realizarán en un laboratorio Linux controlado, aislado y autorizado, manteniendo condiciones comparables entre escenarios y evitando acciones destructivas.	Escala nominal de control: laboratorio Linux controlado, con restauración del estado base, versiones registradas de servicios y pruebas no destructivas.

La variable independiente corresponde al método de cálculo y recalibración del riesgo, debido a que la investigación compara dos formas de estimación: el método estático inicial y el método dinámico adaptativo ARDREC. La variable dependiente corresponde a la precisión de la estimación del riesgo, medida mediante el error absoluto y el error absoluto medio respecto a un criterio externo de referencia experimental. La variable interviniente corresponde a las condiciones técnicas y contextuales del servicio evaluado, debido a que estos factores pueden influir en la valoración del riesgo y en la evidencia obtenida durante la validación. Las variables de control corresponden a los servicios evaluados y al entorno experimental, porque delimitan el alcance técnico de la investigación y permiten mantener condiciones comparables entre escenarios.

6. JUSTIFICACIÓN

La presente investigación se justifica por la necesidad de mejorar la forma en que se estima el riesgo en servicios de infraestructura Linux. Habitualmente, el riesgo se calcula mediante criterios estáticos, considerando exposición, probabilidad de explotación e impacto; sin embargo, dicha estimación no siempre se contrasta con evidencia obtenida durante una verificación controlada.

Esta limitación genera una brecha entre el riesgo teórico calculado inicialmente y las condiciones reales observadas en el servicio evaluado. En servicios como SSH, FTP y SMB, una configuración débil, un acceso permitido o una evidencia verificable modifican la valoración del riesgo. Por ello, la evaluación requiere mecanismos capaces de adaptarse a condiciones técnicas observables, especialmente en entornos donde las amenazas y vulnerabilidades cambian con el tiempo (Cheimonidis y Rantos, 2023).

Frente a esta situación, ARDREC plantea un enfoque dinámico que relaciona el riesgo inicial con resultados obtenidos mediante pruebas controladas. De esta manera, la investigación busca reducir la brecha entre evaluación estática del riesgo y validación

basada en evidencia, aportando un modelo adaptativo, medible y reproducible para entornos Linux controlados.

Así, la propuesta se justifica porque contribuye directamente al objetivo de diseñar y validar experimentalmente un algoritmo adaptativo capaz de recalibrar dinámicamente el riesgo de exposición y compromiso en servicios de infraestructura Linux.

6.1. JUSTIFICACIÓN ECONÓMICA

Desde el punto de vista económico, una estimación más precisa del riesgo permite utilizar de manera más eficiente los recursos destinados a seguridad informática. En contextos institucionales, académicos u organizacionales, el tiempo de análisis, las horas-hombre, los recursos de laboratorio y el esfuerzo técnico son limitados, por lo que resulta necesario priorizar los servicios que requieren mayor atención.

ARDREC contribuye a esta optimización mediante la prioridad adaptativa y los criterios de parada. La prioridad adaptativa orienta las pruebas hacia los servicios con mayor relevancia según el riesgo inicial, la evidencia acumulada y la criticidad contextual. A su vez, los criterios de parada evitan continuar evaluaciones cuando ya existe evidencia suficiente, cuando no hay pruebas aplicables o cuando el riesgo converge.

Esto permite reducir revisiones innecesarias, evitar retrabajo técnico y concentrar el análisis en servicios donde existen condiciones verificables de exposición, acceso o compromiso. Asimismo, una valoración más precisa del riesgo apoya decisiones preventivas orientadas a disminuir interrupciones, incidentes o esfuerzos posteriores de corrección.

Por tanto, el aporte económico de la propuesta se refleja en una mejor asignación del tiempo, del trabajo técnico, de los recursos de laboratorio y de los procesos de validación. Además, la implementación con tecnologías accesibles como Rust y Python

permite desarrollar, probar y ajustar el modelo en un entorno académico sin depender de herramientas comerciales de alto costo durante la fase experimental.

6.2. JUSTIFICACIÓN SOCIAL

Desde el punto de vista social, la seguridad de los servicios de infraestructura Linux se relaciona directamente con la protección de la información, la continuidad de los servicios digitales y la confianza en los sistemas tecnológicos. Servicios como SSH, FTP y SMB son utilizados para administración remota, transferencia de archivos y compartición de recursos; por ello, una configuración débil o una exposición no controlada incrementa el riesgo para usuarios, instituciones y organizaciones que dependen de estos servicios.

En contextos académicos, institucionales y organizacionales, los servidores Linux pueden sostener procesos relacionados con información administrativa, académica, operativa o de investigación. En universidades, instituciones públicas u organizaciones locales, una debilidad técnica expone datos de estudiantes, personal administrativo, usuarios o servicios internos, además de afectar la confianza en los sistemas digitales que respaldan dichos procesos.

Una evaluación más precisa del riesgo permite identificar condiciones verificables de exposición, acceso o compromiso antes de que deriven en incidentes. Esto favorece la protección de datos, la continuidad de servicios educativos e institucionales y la toma de decisiones preventivas basadas en información comprobable.

ARDREC aporta socialmente al promover una práctica responsable de evaluación en ciberseguridad. Al trabajar dentro de un entorno controlado, el modelo evita depender únicamente de estimaciones teóricas o percepciones generales del riesgo, y orienta la atención hacia servicios que presentan condiciones verificables de exposición o compromiso.

La propuesta mantiene un enfoque ético, debido a que excluye malware, daño al sistema, explotación destructiva, evasión avanzada o persistencia maliciosa. Esta delimitación permite que la validación sea adecuada para un laboratorio académico y para escenarios donde se requiere trazabilidad, control y responsabilidad.

La investigación también tiene valor formativo para la comunidad académica, porque integra análisis de riesgo, pentesting controlado, priorización adaptativa y validación experimental. De esta manera, fortalece capacidades locales en ciberseguridad y promueve una cultura preventiva orientada a proteger servicios digitales antes de que una debilidad técnica afecte a usuarios, datos o procesos institucionales.

6.3. JUSTIFICACIÓN CIENTÍFICA

Los modelos dinámicos de evaluación del riesgo buscan actualizar sus estimaciones conforme cambian la información disponible, las vulnerabilidades y las condiciones operativas del entorno evaluado (Cheimonidis y Rantos, 2023). Sobre esta base, ARDREC aporta un modelo formal para recalibrar dinámicamente el riesgo en servicios de infraestructura Linux mediante la incorporación de evidencia técnica verificable.

ISO/IEC (2018) establece que la valoración del riesgo debe considerar activos, amenazas, vulnerabilidades, probabilidad, impacto y contexto organizacional. ARDREC adapta estos elementos mediante variables observables, funciones de cálculo, normalización de valores, ponderaciones y criterios de parada. Esta estructura permite relacionar el riesgo inicial, la evidencia técnica acumulada, la criticidad contextual, la prioridad adaptativa y el riesgo final recalibrado.

La automatización del pentesting permite mejorar la eficiencia, cobertura y organización de las pruebas técnicas de seguridad (Alhamed y Rahman, 2023). Sin embargo, los resultados de estas pruebas suelen permanecer como hallazgos técnicos sin incorporarse directamente en el cálculo formal del riesgo. Esta brecha justifica el desarrollo de un

modelo que transforme la evidencia obtenida durante pruebas controladas en valores cuantificables para recalibrar el riesgo en servicios SSH, FTP y SMB.

Hevner, March, Park y Ram (2004) señalan que un artefacto computacional debe construirse y evaluarse rigurosamente para demostrar su utilidad frente al problema investigado. En correspondencia con este principio, ARDREC será validado mediante la comparación entre el error del método estático y el error del método dinámico respecto a un mismo criterio de referencia experimental. La comparación utilizará el error absoluto, el error absoluto medio y una prueba estadística para muestras emparejadas (Conover, 1999).

La contribución científica de ARDREC consiste en proporcionar un modelo formal, reproducible y evaluable que integre estimación estática, evidencia técnica y contexto dentro de un proceso adaptativo. La decisión multicriterio permite combinar variables con diferentes niveles de importancia dentro de una valoración común (Triantaphyllou, 2000). Asimismo, la estrategia heurística voraz permite priorizar iterativamente las alternativas según el mayor valor calculado en cada estado de evaluación (Cormen, Leiserson, Rivest y Stein, 2009). De esta manera, ARDREC busca reducir la distancia entre el riesgo teórico inicialmente estimado y las condiciones técnicas observadas durante una evaluación controlada.

7. ALCANCES Y LÍMITES

7.1. ALCANCES

La presente investigación considera los siguientes alcances:

- El modelo formal del algoritmo ARDREC para la recalibración dinámica del riesgo de exposición y compromiso en servicios de infraestructura Linux, integrando riesgo inicial, evidencia acumulada, criticidad contextual, prioridad adaptativa y riesgo final recalibrado.

- La representación normalizada de los componentes principales del modelo, considerando exposición, probabilidad de explotación, impacto potencial, evidencia acumulada y criticidad contextual dentro de un dominio común de análisis, facilitando su comparación y tratamiento cuantitativo.
- Las dimensiones observables de evidencia durante la validación técnica, considerando acceso obtenido, nivel de privilegio alcanzado, calidad de evidencia recolectada y confirmación del resultado observado. Esto permitirá que los hallazgos técnicos sean registrados de forma estructurada.
- Las funciones de prioridad adaptativa y de riesgo final recalibrado, orientadas al ordenamiento de la selección de servicios, la ejecución de pruebas y el cálculo del riesgo recalibrado.
- La evaluación experimental de los servicios SSH, FTP y SMB en un entorno Linux controlado, debido a su relevancia en administración remota, transferencia de archivos y compartición de recursos en red. Esta evaluación permitirá observar distintos escenarios técnicos, registrar evidencia verificable y comparar el comportamiento del riesgo antes y después de la recalibración dinámica.
- El prototipo experimental para la ejecución del flujo principal de ARDREC, contemplando descubrimiento, enumeración, validación controlada, registro de evidencia, priorización adaptativa y cálculo del riesgo final.
- La arquitectura modular del prototipo, contemplando un componente técnico en Rust, un componente analítico en Python y estructuras JSON para el intercambio de información entre ambos componentes, manteniendo separación entre evidencia técnica y análisis del riesgo.
- Los criterios de parada, pesos iniciales uniformes y análisis de sensibilidad, considerando evidencia suficiente, ausencia de pruebas aplicables, convergencia del riesgo, límite máximo de iteraciones y variaciones en la importancia relativa de los componentes del modelo. Estos elementos permitirán controlar la ejecución experimental.

- La validación experimental del modelo, mediante una rúbrica de referencia, comparación entre el método estático y ARDREC, indicadores de error, prueba estadística para muestras emparejadas, generación de resultados comparativos, reportes experimentales y documentación del proceso.

7.2. LÍMITES

La presente investigación establece los siguientes límites:

- La investigación se limita a entornos Linux y a los servicios SSH, FTP y SMB; por tanto, no se evaluarán otros sistemas operativos ni servicios como HTTP, HTTPS, Telnet, MySQL, PostgreSQL, DNS, SMTP u otros servicios de red.
- La validación del algoritmo se realizará únicamente en un entorno de laboratorio controlado, por lo que no forma parte del estudio su aplicación en entornos de producción reales.
- La unidad de análisis será el escenario-servicio evaluado en laboratorio, por lo que no se abarcará la evaluación integral de una red completa, una organización completa o una infraestructura empresarial real.
- Se excluye la ejecución de pruebas sobre redes, equipos o servicios externos al entorno autorizado y definido para la investigación.
- La investigación no utilizará información sensible real, debido a que el entorno experimental trabajará con datos simulados o controlados.
- Se excluyen pruebas destructivas, daño al sistema, interrupción deliberada de servicios, degradación del servicio o alteración de archivos críticos del sistema evaluado.
- Queda fuera del alcance el uso de malware, ransomware, troyanos, rootkits, backdoors, evasión avanzada, ocultamiento, persistencia maliciosa o movimiento lateral.
- El prototipo no será desarrollado como framework ofensivo general de explotación, herramienta comercial de pentesting ni sustituto de una auditoría profesional completa.

- No forma parte del alcance la implementación de aprendizaje automático, algoritmos evolutivos, redes neuronales, aprendizaje por refuerzo u otros métodos de inteligencia artificial para ajustar automáticamente los pesos o parámetros del modelo.
- El modelo no se plantea como definitivo, universal o directamente generalizable a todos los servicios, plataformas o contextos organizacionales; además, no se comparará ARDREC contra todos los estándares, metodologías o herramientas existentes, ni se utilizarán CVE, CVSS, EPSS, inteligencia de amenazas o bases externas de explotación como criterio principal de evaluación.
- La implementación de interfaces avanzadas, grafos forenses completos, visualizaciones complejas, alta disponibilidad, monitoreo en tiempo real, procesamiento de grandes volúmenes de datos empresariales o características de producto comercial no será una condición principal de la investigación.

8. APORTES

8.1. APORTE TEÓRICO

El aporte teórico de la presente investigación consiste en la formulación del algoritmo ARDREC como un modelo adaptativo para recalibrar dinámicamente el riesgo de exposición y compromiso en servicios de infraestructura Linux. Los modelos dinámicos permiten actualizar la valoración del riesgo conforme cambian la información disponible y las condiciones del entorno evaluado (Cheimonidis y Rantos, 2023). Sobre esta base, ARDREC integra la evaluación inicial del riesgo con la validación técnica basada en evidencia.

Las evaluaciones técnicas de seguridad permiten obtener evidencia verificable mediante el descubrimiento de servicios, la identificación de vulnerabilidades y la validación controlada de debilidades (NIST, 2008). ARDREC incorpora esta evidencia como parte del cálculo formal del riesgo, relacionando riesgo inicial, evidencia técnica acumulada, criticidad contextual, prioridad adaptativa y riesgo final recalibrado dentro de una estructura medible, normalizada y contrastable.

Desde el punto de vista metodológico, el aporte se apoya en Design Science Research, debido a que la investigación propone, construye y evalúa un artefacto computacional orientado a resolver un problema identificado (Hevner et al., 2004). En esta investigación, el artefacto está representado por el algoritmo ARDREC y su correspondiente modelo formal de recalibración dinámica del riesgo.

Desde el punto de vista algorítmico, ARDREC emplea una estrategia heurística voraz adaptativa para seleccionar en cada iteración la alternativa con mayor valor calculado, sin explorar exhaustivamente todas las combinaciones posibles (Cormen et al., 2009). Asimismo, utiliza decisión multicriterio ponderada para integrar variables con diferentes niveles de importancia dentro de una valoración común (Triantaphyllou, 2000). Esta combinación permite actualizar la selección de pruebas conforme se incorpora nueva evidencia técnica durante la validación controlada.

El modelo también aporta una estructura conceptual para diferenciar la prioridad operativa del riesgo final recalibrado. La prioridad adaptativa orienta la selección de servicios y pruebas, mientras que el riesgo final recalibrado representa el resultado que será contrastado experimentalmente. Esta separación fortalece la trazabilidad del proceso y permite transformar hallazgos técnicos verificables en insumos cuantificables para la recalibración dinámica del riesgo en servicios de infraestructura Linux.

8.2. APOORTE PRÁCTICO

El aporte práctico de la presente investigación consiste en la implementación de un prototipo experimental basado en ARDREC, orientado a validar en laboratorio la recalibración dinámica del riesgo en servicios de infraestructura Linux.

El prototipo permitirá aplicar el flujo principal del modelo sobre servicios SSH, FTP y SMB, considerando descubrimiento, enumeración, validación controlada, registro de evidencia, priorización adaptativa y cálculo del riesgo final. Su finalidad será demostrar

la viabilidad operativa del algoritmo dentro de un entorno autorizado, delimitado y reproducible.

Desde el punto de vista de ingeniería, el aporte práctico se materializa en una arquitectura modular que separa la obtención controlada de evidencia del procesamiento analítico del modelo. Esta separación permite organizar el prototipo de manera clara, reproducible y extensible para fines experimentales, sin convertirlo en una herramienta comercial de pentesting.

El prototipo permitirá registrar de manera estructurada los servicios detectados, las pruebas ejecutadas, los resultados obtenidos, la evidencia registrada y los valores calculados por ARDREC. Esta estructura facilitará la repetición de los experimentos y la comparación entre el método estático y el método dinámico propuesto.

También se generarán resultados y reportes experimentales que permitan observar cómo la evidencia obtenida durante la validación modifica la valoración inicial del riesgo. Estos reportes estarán orientados a describir el servicio evaluado, el resultado de la prueba, el riesgo inicial, el riesgo final recalibrado y las recomendaciones derivadas.

El aporte práctico se concreta en una herramienta experimental ejecutable y documentada, útil para validar ARDREC dentro del alcance definido por la investigación. El prototipo no constituye una auditoría profesional completa, sino un medio práctico para demostrar la aplicabilidad del modelo propuesto en un entorno académico y controlado.

9. METODOLOGÍA

La presente investigación se desarrollará con enfoque cuantitativo, orientación positivista y tipo aplicada-tecnológica, debido a que busca diseñar y validar experimentalmente un artefacto computacional orientado a recalibrar dinámicamente el riesgo de exposición y compromiso en servicios de infraestructura Linux. La

metodología se organizará en dos partes: metodología de investigación y metodología de desarrollo de ingeniería.

9.1. METODOLOGÍA DE INVESTIGACIÓN

La investigación seguirá un enfoque cuantitativo, porque la validación se realizará mediante valores numéricos de riesgo, evidencia técnica, criticidad contextual, error absoluto y error absoluto medio, definidos en la operacionalización de variables. El tipo de investigación será aplicada-tecnológica, ya que se propone un artefacto computacional para resolver un problema específico de recalibración dinámica del riesgo en servicios de infraestructura Linux.

El método de investigación será hipotético-deductivo, debido a que se parte de una hipótesis previamente formulada y se contrasta mediante datos obtenidos en un entorno experimental controlado. Para ello, se comparará un método estático de estimación del riesgo con el método dinámico adaptativo ARDREC sobre los mismos escenarios-servicio.

Asimismo, la investigación se apoyará en Design Science Research, porque el estudio propone, construye y evalúa un artefacto computacional. En este caso, el artefacto estará representado por el algoritmo ARDREC y su prototipo experimental. Esta metodología permitirá relacionar el ciclo de relevancia, vinculado con el problema de recalibración del riesgo; el ciclo de rigor, sustentado en evaluación de riesgos, diseño algorítmico y validación estadística; y el ciclo de diseño, orientado a la construcción, demostración y evaluación del artefacto (Hevner et al., 2004).

El diseño experimental será comparativo y emparejado. Cada escenario-servicio será evaluado mediante dos métodos: el método estático inicial y el método dinámico ARDREC. La comparación se realizará sobre los mismos escenarios, con el propósito de medir la diferencia entre ambos métodos respecto a un criterio externo de referencia experimental.

La unidad de análisis será el escenario-servicio evaluado en laboratorio, compuesto por un servicio de infraestructura Linux, SSH, FTP o SMB, configurado bajo una condición experimental determinada. La muestra será intencional y estará conformada por un mínimo de 45 observaciones, distribuidas en 15 escenarios por servicio. Esta cantidad permitirá cubrir condiciones diferenciadas de exposición, evidencia técnica y criticidad contextual, considerando escenarios seguros, escenarios con configuraciones débiles y escenarios con evidencia verificable de riesgo.

El criterio externo de referencia experimental será definido mediante una rúbrica previa e independiente del cálculo de ARDREC, con el fin de evitar medición circular. Esta rúbrica considerará el estado conocido del escenario, la configuración técnica del servicio, la evidencia observable, el nivel de acceso obtenido, el privilegio alcanzado y la criticidad contextual. Los valores de referencia se expresarán en una escala normalizada de 0.00 a 1.00 y la rúbrica será revisada previamente mediante criterio técnico del tutor o de un evaluador experto, con el propósito de fortalecer su validez de contenido.

Para fortalecer la validez interna del experimento, el laboratorio mantendrá condiciones controladas: aislamiento de red, versiones registradas de servicios, restauración del estado base entre escenarios, registro de configuraciones y ejecución no destructiva de pruebas. En pruebas dependientes de respuestas de red, tiempos de servicio o variaciones del entorno, se realizarán tres corridas y se utilizará un valor promedio; en escenarios deterministas, definidos por configuraciones conocidas y resultados verificables, una ejecución controlada será suficiente.

Las técnicas de investigación serán la observación experimental, el registro estructurado de evidencias, la comparación de resultados y el análisis estadístico. Los instrumentos serán la rúbrica externa de referencia experimental, las bitácoras de registro, las tablas de cálculo del error absoluto, el error absoluto medio y la prueba de rangos con signo de Wilcoxon para muestras emparejadas.

El contraste estadístico se realizará con un nivel de significancia de $\alpha = 0.05$. La hipótesis nula establecerá que el error del método dinámico ARDREC no es menor que el error del método estático; mientras que la hipótesis alternativa establecerá que el error del método dinámico ARDREC es menor que el error del método estático. Se considerará que ARDREC mejora la estimación del riesgo si el error absoluto medio del método dinámico adaptativo es menor que el error absoluto medio del método estático y si la diferencia resulta estadísticamente significativa según la prueba de Wilcoxon. Además del valor de significancia, se reportará el tamaño del efecto para valorar la magnitud práctica de la mejora observada (Conover, 1999).

9.2. METODOLOGÍA DE DESARROLLO DE INGENIERÍA

Para el desarrollo de ingeniería se utilizará el modelo incremental con prototipado evolutivo y arquitectura modular. El desarrollo incremental permite construir el sistema mediante componentes funcionales, evaluarlos individualmente e integrarlos progresivamente hasta obtener un producto operativo (Sommerville, 2011). Esta metodología se adopta porque el prototipo ARDREC constituye un artefacto experimental y no un sistema comercial definitivo.

El desarrollo se organizará en las siguientes fases: análisis de requisitos experimentales, diseño algorítmico de ARDREC, diseño arquitectónico modular, construcción incremental del prototipo, pruebas e integración de módulos, evaluación experimental y documentación de resultados.

En la fase de análisis de requisitos experimentales se definirán los servicios que serán evaluados, las entradas y salidas del algoritmo, las restricciones del laboratorio, las reglas de ejecución segura y los datos requeridos para la comparación experimental. También se establecerán los criterios necesarios para contrastar el método estático inicial con el método dinámico ARDREC.

En la fase de diseño algorítmico se formalizarán el riesgo inicial, la evidencia técnica acumulada, la criticidad contextual, la prioridad adaptativa y el riesgo final recalibrado. También se definirán las escalas de medición, la normalización de variables en el intervalo $[0,1]$, las funciones ponderadas, los pesos iniciales y los criterios de parada. ARDREC utilizará una estrategia heurística voraz adaptativa para seleccionar en cada iteración la alternativa con mayor valor calculado (Cormen et al., 2009). Asimismo, empleará decisión multicriterio ponderada para integrar los componentes del modelo de acuerdo con su importancia relativa (Triantaphyllou, 2000).

En la fase de diseño arquitectónico modular se definirá la estructura del prototipo. Bass, Clements y Kazman (2012) señalan que la separación de responsabilidades facilita la organización y evaluación de los componentes de una arquitectura de software. En correspondencia con este principio, ARDREC separará el componente técnico, encargado de la interacción controlada con los servicios, del componente analítico, responsable del procesamiento de datos, cálculo del riesgo y generación de resultados.

En la fase de construcción incremental se implementarán los módulos de descubrimiento de servicios, enumeración, validación técnica controlada, registro de evidencia, cálculo de prioridad adaptativa, cálculo del riesgo final recalibrado y generación de resultados experimentales. El componente técnico se desarrollará en Rust y el componente analítico se implementará en Python. Python facilitará el procesamiento estructurado de los datos y el análisis de los resultados experimentales (McKinney, 2022). El intercambio de información entre ambos componentes se realizará mediante estructuras JSON.

Durante cada incremento se establecerán criterios de aceptación relacionados con las entradas, salidas y comportamiento esperado de los módulos implementados. Cada componente deberá superar pruebas unitarias antes de integrarse al siguiente incremento, permitiendo detectar errores progresivamente y reducir problemas durante la integración final (Sommerville, 2011).

En la fase de pruebas e integración se verificará el funcionamiento individual y conjunto de los módulos. Las estructuras JSON incluirán identificadores para cada escenario-servicio y serán verificadas mediante un esquema previamente definido. Esto permitirá asociar cada evidencia registrada con su correspondiente cálculo de prioridad, riesgo recalibrado y resultado experimental. También se mantendrá el control de versiones del prototipo y el registro de las configuraciones del laboratorio.

Para garantizar la trazabilidad de la validación técnica, cada ejecución registrará el escenario, servicio evaluado, prueba aplicada, parámetros utilizados, resultado obtenido y evidencia generada. NIST (2008) establece que las evaluaciones técnicas deben documentar sus procedimientos y resultados para facilitar su verificación. Estos registros permitirán reconstruir cada prueba y comprobar la relación entre la evidencia obtenida y el riesgo recalibrado.

En la fase de evaluación experimental se ejecutarán los escenarios definidos para los servicios SSH, FTP y SMB dentro de un laboratorio Linux controlado. Cada escenario será evaluado mediante el método estático inicial y el método dinámico ARDREC. Los resultados serán comparados con una rúbrica externa de referencia para calcular el error absoluto, el error absoluto medio y la diferencia entre ambos métodos. También se aplicará un análisis de sensibilidad para estudiar la estabilidad del modelo frente a variaciones controladas de sus pesos (Saltelli et al., 2008).

Finalmente, en la fase de documentación se registrarán el pseudocódigo de ARDREC, la arquitectura modular, los módulos implementados, las estructuras JSON, las configuraciones del laboratorio y las bitácoras de evidencia. También se documentarán el riesgo inicial, la evidencia acumulada, la criticidad contextual, la prioridad adaptativa, el riesgo final recalibrado, los cálculos de error y los resultados estadísticos de cada escenario evaluado. Esta documentación permitirá sustentar la trazabilidad y reproducibilidad del proceso experimental.

10. MARCO TEÓRICO

La recalibración adaptativa del riesgo en servicios de infraestructura Linux requiere una base conceptual que articule evaluación de riesgos, evidencia técnica, criticidad contextual, pentesting controlado, arquitectura modular y validación experimental. Estos fundamentos permiten sustentar ARDREC como un modelo orientado a estimar un riesgo inicial, incorporar evidencia verificable y contrastar el riesgo recalibrado frente a una referencia experimental definida previamente.

La evaluación de riesgos en ciberseguridad constituye el punto de partida para estimar condiciones de exposición en servicios tecnológicos. ISO/IEC (2018) establece que la gestión del riesgo de seguridad de la información relaciona activos, amenazas, vulnerabilidades, probabilidad de ocurrencia e impacto. De forma complementaria, NIST (2012) señala que la evaluación de riesgos permite identificar amenazas, vulnerabilidades, condiciones predisponentes, probabilidad, magnitud del impacto y nivel resultante de riesgo. En ARDREC, estos criterios serán adaptados a tres dimensiones iniciales: exposición, probabilidad de explotación e impacto potencial.

Los modelos de puntuación de vulnerabilidades permiten representar técnicamente la severidad de una condición de seguridad. Forum of Incident Response and Security Teams (FIRST, 2024) presenta CVSS como un sistema de puntuación orientado a expresar características técnicas de vulnerabilidades mediante métricas de explotación e impacto. ARDREC no utilizará CVSS como cálculo directo, sino como fundamento conceptual para establecer una puntuación inicial normalizada que posteriormente será contrastada con evidencia técnica obtenida en laboratorio.

La priorización del riesgo requiere complementar la severidad inicial con información observada durante la evaluación. Jacobs, Romanosky, Edwards, Roytman y Adjerd (2019) proponen EPSS como un sistema orientado a estimar la probabilidad de explotación de vulnerabilidades a partir de datos observados. En el caso de ARDREC, EPSS no será usado como fuente directa de datos, debido a que su alcance se orienta a

vulnerabilidades públicas en contextos reales; sin embargo, sirve como base conceptual para justificar que la priorización puede enriquecerse mediante evidencia verificable.

La evaluación dinámica del riesgo permite modificar una estimación inicial cuando cambian las condiciones del entorno, la información disponible o el estado técnico del activo evaluado. Cheimonidis y Rantos (2023) señalan que los enfoques dinámicos buscan responder a escenarios donde las amenazas, vulnerabilidades y condiciones operativas varían con el tiempo. En ARDREC, esta actualización será entendida como recalibración, porque ajustará la estimación inicial mediante evidencia técnica y la contrastará posteriormente con una referencia experimental externa.

La evidencia técnica acumulada representa el componente verificable del modelo. Esta evidencia se obtendrá mediante pruebas controladas y se expresará a partir de cuatro dimensiones: acceso obtenido, nivel de privilegio, calidad de evidencia y confirmación técnica. La ausencia de evidencia no será interpretada como ausencia absoluta de vulnerabilidad, sino como ausencia de evidencia verificable dentro del alcance, las pruebas y las condiciones definidas para el laboratorio. De esta manera, ARDREC permitirá diferenciar entre riesgo estimado y riesgo observado bajo condiciones controladas.

La criticidad contextual permitirá incorporar la importancia operativa, técnica o informacional del servicio evaluado. ISO/IEC (2018) sostiene que la valoración del riesgo puede ajustarse según el valor del activo y las necesidades del contexto. Por ello, la criticidad permitirá diferenciar servicios con condiciones técnicas similares, pero con distinta relevancia dentro del escenario experimental.

Las variables principales del modelo serán normalizadas en el intervalo $[0,1]$ para integrar riesgo inicial, evidencia técnica acumulada y criticidad contextual en una escala común. A partir de estos componentes se obtendrán dos salidas diferenciadas: la prioridad adaptativa y el riesgo final recalibrado. La prioridad adaptativa tendrá una finalidad operativa, porque ordenará la selección de servicios y pruebas; en cambio, el

riesgo final recalibrado tendrá una finalidad evaluativa, porque será comparado con el valor de referencia experimental.

Las pruebas técnicas de seguridad se desarrollarán mediante pentesting controlado. NIST (2008) establece que las evaluaciones técnicas de seguridad pueden incluir descubrimiento de red, escaneo de puertos, identificación de vulnerabilidades y validación técnica de debilidades. PCI SSC (2017) diferencia la prueba de penetración de un escaneo de vulnerabilidades, debido a que requiere alcance definido, reglas de compromiso, ejecución controlada, reporte y verificación posterior. Bajo este criterio, las pruebas se limitarán a escenarios autorizados, controlados y no destructivos.

La metodología PTES será utilizada como guía operativa para organizar la recolección de evidencia técnica. Ridwan (2024) describe PTES mediante fases como pre-engagement, intelligence gathering, threat modelling, vulnerability analysis, exploitation, post-exploitation y reporting. En ARDREC, estas fases serán adaptadas al laboratorio: delimitación del entorno, identificación de hosts y servicios, observación de condiciones técnicas, validación no destructiva y registro de resultados. PTES organizará el proceso técnico, mientras que ARDREC cuantificará los hallazgos mediante variables de riesgo y evidencia.

Para la identificación técnica de servicios se utilizará escaneo de red y detección de versiones. Lyon (2008) presenta Nmap como una herramienta capaz de identificar hosts activos, puertos abiertos, servicios y versiones. Marsh (2010) describe su aplicación en escaneo de subredes, detección de puertos y reconocimiento de servicios. Estos resultados permitirán verificar si los servicios SSH, FTP y SMB están activos, accesibles y técnicamente observables.

Los servicios SSH, FTP y SMB/Samba constituyen el dominio técnico delimitado de la investigación. SSH será considerado a partir de Ylönen y Lonvick (2006), FTP con base en Postel y Reynolds (1985), SMB según Microsoft Corporation (2026), y Samba conforme a Terpstra y Vernooij (2005). Estos servicios permiten observar evidencia

diferenciada, como autenticación remota, transferencia de archivos, permisos de lectura y acceso a recursos compartidos.

Desde la ingeniería de software, ARDREC será organizado bajo una arquitectura modular que separe adquisición de datos, procesamiento, cálculo de riesgo, validación experimental y generación de resultados. Sommerville (2011) plantea que la ingeniería de software comprende los aspectos necesarios para la producción sistemática de software, mientras que Bass et al. (2012) señalan que la arquitectura permite razonar sobre componentes, estructuras y propiedades visibles del sistema. Esta base permitirá separar módulos de escaneo, normalización, cálculo estático, recalibración dinámica, comparación estadística y reporte experimental.

Para el procesamiento de datos experimentales se utilizarán herramientas de automatización y análisis. Lutz (2009) destaca la utilidad de Python para programación de sistemas y automatización, mientras que McKinney (2022) presenta pandas y NumPy como herramientas para manipulación y análisis de datos. Estas herramientas permitirán registrar resultados, normalizar variables, calcular indicadores del modelo, comparar errores y generar resultados experimentales reproducibles.

La validación experimental se fundamentará en un diseño comparativo entre el método estático inicial y el método dinámico adaptativo ARDREC. Montgomery (2004) señala que el diseño experimental permite evaluar el efecto de variables controladas sobre una respuesta medible. Walpole, Myers, Myers y Ye (2012) explican que la estadística permite analizar variabilidad, estimar resultados y sustentar conclusiones a partir de datos observados. En este caso, la respuesta experimental será el error absoluto respecto a una rúbrica de referencia definida antes de ejecutar las pruebas.

La referencia experimental, R_{ref_i} , representará el valor externo asignado a cada escenario-servicio según el estado verificable observado en el laboratorio. Este valor no será calculado mediante ARDREC ni mediante la función de riesgo final recalibrado, con el fin de evitar una medición circular. Su finalidad será actuar como patrón

independiente para comparar el error del método estático inicial y el error del método dinámico adaptativo.

La medición del error permitirá comparar el riesgo estático inicial y el riesgo recalibrado por ARDREC frente al mismo criterio de referencia. Para ello se utilizarán el error absoluto y el error absoluto medio, indicadores que permitirán determinar si el riesgo final recalibrado se aproxima mejor al valor experimental que el riesgo inicial. Esta comparación será realizada sobre los mismos escenarios, manteniendo el carácter emparejado del diseño experimental.

Para contrastar estadísticamente la hipótesis se aplicará la prueba de rangos con signo de Wilcoxon para muestras emparejadas. Conover (1999) desarrolla métodos no paramétricos aplicables cuando no se cumplen supuestos estrictos de normalidad. En ARDREC, Wilcoxon permitirá comparar los errores del método estático y los errores del método dinámico sobre los mismos escenarios experimentales.

Adicionalmente, se aplicará análisis de sensibilidad sobre los pesos del modelo. Saltelli et al. (2008) señalan que el análisis de sensibilidad permite estudiar cómo la variación de los factores de entrada afecta la salida de un modelo. Esta técnica permitirá evaluar la estabilidad de la prioridad adaptativa y del riesgo final recalibrado frente a cambios en los pesos β , λ y w .

Los fundamentos desarrollados sustentan la aplicación de ARDREC mediante evaluación de riesgo, evidencia técnica, criticidad contextual, pentesting controlado, arquitectura modular, validación experimental, Wilcoxon y análisis de sensibilidad. Esta base conceptual permite abordar la investigación de forma coherente con la hipótesis, los objetivos, las variables y el alcance experimental definido. Asimismo, orienta la interpretación reproducible de los resultados obtenidos en los servicios SSH, FTP y SMB.

11. ÍNDICE TENTATIVO

CAPÍTULO I

MARCO INTRODUCTORIO

1.1. Introducción

1.2. Antecedentes

1.3. Planteamiento del problema

1.3.1. Problema central

1.3.2. Problemas secundarios

1.4. Objetivos

1.4.1. Objetivo general

1.4.2. Objetivos específicos

1.5. Hipótesis y operacionalización de variables

1.5.1. Operacionalización de variables

1.6. Justificación

1.6.1. Justificación económica

1.6.2. Justificación social

1.6.3. Justificación científica

1.7. Alcances y límites

1.7.1. Alcances

1.7.2. Límites

1.8. Aportes de la investigación

1.8.1. Aporte teórico

1.8.2. Aporte práctico

1.9. Diseño metodológico general

1.9.1. Paradigma, enfoque y tipo de investigación

1.9.2. Método de investigación

1.9.3. Diseño experimental y comparativo

1.9.4. Unidad de análisis y muestra experimental

1.9.5. Técnicas e instrumentos de investigación

CAPÍTULO II

MARCO TEÓRICO

2.1. Fundamentos de ciberseguridad en infraestructuras Linux

2.1.1. Servicios de infraestructura en entornos Linux

2.1.2. Exposición, acceso y compromiso técnico

2.1.3. Servicios SSH, FTP y SMB/Samba

2.2. Gestión y evaluación de riesgos en ciberseguridad

2.2.1. Riesgo, amenaza, vulnerabilidad, probabilidad e impacto

2.2.2. Evaluación estática del riesgo

2.2.3. Evaluación dinámica del riesgo

2.2.4. Criticidad contextual de activos y servicios

2.3. Modelos de puntuación y priorización de vulnerabilidades

2.3.1. Sistema CVSS

2.3.2. Sistema EPSS

2.3.3. Limitaciones de los modelos estáticos frente a evidencia técnica

2.4. Pentesting controlado y validación técnica

2.4.1. Evaluaciones técnicas de seguridad

2.4.2. Pruebas de penetración controladas

2.4.3. Metodología PTES

2.4.4. Reglas de compromiso y límites éticos del laboratorio

2.5. Evidencia técnica en procesos de evaluación de riesgo

2.5.1. Acceso obtenido

2.5.2. Nivel de privilegio

2.5.3. Calidad de evidencia

2.5.4. Confirmación técnica del hallazgo

2.6. Fundamentos de modelado algorítmico

2.6.1. Representación formal de servicios

2.6.2. Normalización de variables

2.6.3. Funciones ponderadas de decisión

- 2.6.4. Sistemas adaptativos basados en estados
- 2.7. Fundamentos estadísticos para la validación experimental
 - 2.7.1. Error absoluto
 - 2.7.2. Error Absoluto Medio
 - 2.7.3. Comparación emparejada
 - 2.7.4. Prueba de rangos con signo de Wilcoxon
 - 2.7.5. Análisis de sensibilidad paramétrica

CAPÍTULO III

MARCO APLICATIVO: FORMALIZACIÓN, DISEÑO E IMPLEMENTACIÓN DE ARDREC

- 3.1. Descripción general del modelo ARDREC
 - 3.1.1. Propósito del algoritmo
 - 3.1.2. Alcance técnico del modelo
 - 3.1.3. Supuestos de diseño
 - 3.1.4. Restricciones operativas y éticas
- 3.2. Representación formal del espacio de servicios
 - 3.2.1. Definición de la unidad servicio-escenario
 - 3.2.2. Atributos técnicos del servicio evaluado
 - 3.2.3. Atributos contextuales del servicio evaluado
 - 3.2.4. Estado dinámico del servicio durante la evaluación
- 3.3. Modelo de riesgo inicial
 - 3.3.1. Exposición del servicio
 - 3.3.2. Probabilidad inicial de explotación
 - 3.3.3. Impacto potencial
 - 3.3.4. Normalización del riesgo inicial
- 3.4. Modelo de evidencia técnica acumulada
 - 3.4.1. Dimensiones observables de evidencia

- 3.4.2. Función de evidencia técnica
 - 3.4.3. Ponderación de evidencia mediante pesos β
 - 3.4.4. Normalización de la evidencia técnica
- 3.5. Modelo de criticidad contextual
 - 3.5.1. Escala de criticidad contextual
 - 3.5.2. Normalización de la criticidad
 - 3.5.3. Influencia de la criticidad en el modelo ARDREC
- 3.6. Función de prioridad adaptativa
 - 3.6.1. Componentes de la prioridad adaptativa
 - 3.6.2. Ponderación mediante pesos λ
 - 3.6.3. Selección adaptativa de servicios y pruebas
 - 3.6.4. Diferencia entre prioridad operativa y riesgo final
- 3.7. Función de riesgo final recalibrado
 - 3.7.1. Componentes del riesgo final
 - 3.7.2. Ponderación mediante pesos w
 - 3.7.3. Recalibración dinámica del riesgo
 - 3.7.4. Interpretación del riesgo final reportable
- 3.8. Propiedades formales del modelo
 - 3.8.1. Acotación de variables normalizadas en el intervalo $[0,1]$
 - 3.8.2. Monotonía respecto a los componentes del modelo
 - 3.8.3. Estabilidad frente a variaciones de pesos
 - 3.8.4. Trazabilidad de decisiones algorítmicas
- 3.9. Catálogo de pruebas técnicas controladas
 - 3.9.1. Pruebas aplicables a SSH
 - 3.9.2. Pruebas aplicables a FTP
 - 3.9.3. Pruebas aplicables a SMB/Samba
 - 3.9.4. Condiciones de ejecución segura de pruebas
- 3.10. Criterios de parada del algoritmo
 - 3.10.1. Evidencia técnica suficiente

- 3.10.2. Ausencia de pruebas aplicables
 - 3.10.3. Convergencia del riesgo recalibrado
 - 3.10.4. Límite máximo de iteraciones
- 3.11. Pseudocódigo, flujo y análisis computacional de ARDREC
 - 3.11.1. Entradas del algoritmo
 - 3.11.2. Salidas del algoritmo
 - 3.11.3. Flujo iterativo de evaluación
 - 3.11.4. Máquina de estados del proceso adaptativo
 - 3.11.5. Complejidad temporal y espacial
- 3.12. Arquitectura modular del prototipo
 - 3.12.1. Componente técnico de descubrimiento y validación
 - 3.12.2. Componente analítico de cálculo y recalibración
 - 3.12.3. Intercambio de información mediante estructuras JSON
 - 3.12.4. Registro de evidencias y resultados
- 3.13. Implementación experimental de ARDREC
 - 3.13.1. Módulo de descubrimiento de servicios
 - 3.13.2. Módulo de enumeración y validación técnica
 - 3.13.3. Motor de cálculo del riesgo inicial
 - 3.13.4. Motor de evidencia técnica acumulada
 - 3.13.5. Motor de prioridad adaptativa y riesgo final
 - 3.13.6. Interfaz TUI para seguimiento del proceso
 - 3.13.7. Generación de reportes experimentales

CAPÍTULO IV

PRUEBA DE HIPÓTESIS

- 4.1. Diseño experimental de la investigación
 - 4.1.1. Diseño comparativo y emparejado
 - 4.1.2. Unidad experimental escenario-servicio
 - 4.1.3. Estructura mínima de observaciones experimentales

- 4.1.4. Control de condiciones del laboratorio
- 4.2. Entorno experimental
 - 4.2.1. Infraestructura Linux controlada
 - 4.2.2. Configuración de servicios SSH
 - 4.2.3. Configuración de servicios FTP
 - 4.2.4. Configuración de servicios SMB/Samba
 - 4.2.5. Herramientas técnicas utilizadas
- 4.3. Escenarios experimentales
 - 4.3.1. Escenarios seguros
 - 4.3.2. Escenarios con exposición controlada
 - 4.3.3. Escenarios con acceso verificable
 - 4.3.4. Distribución experimental por servicio
- 4.4. Rúbrica externa de referencia experimental
 - 4.4.1. Definición de $Rref_i$
 - 4.4.2. Criterios de asignación del valor de referencia
 - 4.4.3. Independencia de la rúbrica respecto a ARDREC
 - 4.4.4. Control de medición circular
- 4.5. Ejecución del método estático inicial
 - 4.5.1. Asignación de exposición, probabilidad e impacto
 - 4.5.2. Cálculo del riesgo inicial normalizado
 - 4.5.3. Registro de resultados del método estático
- 4.6. Ejecución del método dinámico ARDREC
 - 4.6.1. Descubrimiento y selección de servicios
 - 4.6.2. Validación técnica controlada
 - 4.6.3. Acumulación de evidencia
 - 4.6.4. Cálculo de prioridad adaptativa
 - 4.6.5. Cálculo del riesgo final recalibrado
- 4.7. Métricas de evaluación
 - 4.7.1. Error absoluto del método estático

- 4.7.2. Error absoluto del método ARDREC
- 4.7.3. Error Absoluto Medio del método estático
- 4.7.4. Error Absoluto Medio del método ARDREC
- 4.7.5. Indicadores complementarios de eficiencia adaptativa
- 4.8. Contraste estadístico de la hipótesis
 - 4.8.1. Formulación de hipótesis nula y alternativa
 - 4.8.2. Aplicación de la prueba de Wilcoxon para muestras emparejadas
 - 4.8.3. Nivel de significancia y criterio de decisión
 - 4.8.4. Interpretación estadística de resultados
- 4.9. Análisis de sensibilidad paramétrica
 - 4.9.1. Sensibilidad de pesos β
 - 4.9.2. Sensibilidad de pesos λ
 - 4.9.3. Sensibilidad de pesos w
 - 4.9.4. Estabilidad del modelo frente a variaciones controladas
- 4.10. Presentación de resultados experimentales
 - 4.10.1. Resultados por servicio evaluado
 - 4.10.2. Resultados por tipo de escenario
 - 4.10.3. Comparación global entre método estático y ARDREC
 - 4.10.4. Comportamiento del riesgo antes y después de la recalibración
- 4.11. Discusión de resultados
 - 4.11.1. Interpretación frente al problema de investigación
 - 4.11.2. Interpretación frente a los objetivos específicos
 - 4.11.3. Interpretación frente a la hipótesis
 - 4.11.4. Relación con los antecedentes revisados
 - 4.11.5. Eficiencia adaptativa y esfuerzo técnico observado
- 4.12. Amenazas a la validez experimental
 - 4.12.1. Validez interna
 - 4.12.2. Validez externa
 - 4.12.3. Validez de constructo

4.12.4. Reproducibilidad de los resultados

CAPÍTULO V

CONCLUSIONES Y RECOMENDACIONES

5.1. Conclusiones

- 5.1.1. Conclusiones respecto al problema central
- 5.1.2. Conclusiones respecto a los problemas secundarios
- 5.1.3. Conclusiones respecto al objetivo general
- 5.1.4. Conclusiones respecto a los objetivos específicos
- 5.1.5. Conclusiones respecto a la hipótesis de investigación

5.2. Aportes finales de la investigación

- 5.2.1. Aporte teórico del modelo ARDREC
- 5.2.2. Aporte práctico del prototipo experimental
- 5.2.3. Aporte metodológico de la validación emparejada

5.3. Limitaciones del estudio

- 5.3.1. Limitaciones del entorno experimental
- 5.3.2. Limitaciones del alcance técnico
- 5.3.3. Limitaciones de generalización del modelo

5.4. Recomendaciones

- 5.4.1. Recomendaciones para futuras implementaciones
- 5.4.2. Recomendaciones para validaciones experimentales posteriores
- 5.4.3. Recomendaciones para ampliación del modelo

5.5. Trabajos futuros

- 5.5.1. Incorporación de nuevos servicios de infraestructura
- 5.5.2. Integración de fuentes externas como CVE, CVSS o EPSS
- 5.5.3. Ajuste automático de pesos mediante técnicas inteligentes
- 5.5.4. Evaluación en entornos organizacionales reales autorizados

12. CRONOGRAMA DE AVANCE

CRONOGRAMA DE AVANCE DE TESIS – ARDREC															
Periodo: 1 de agosto al 2 de diciembre de 2026															
PLAN DE ACTIVIDADES						AGOSTO		SEPTIEMBRE		OCTUBRE		NOVIEMBRE		DICIEMBRE	
Nº	Fase	Actividad	Inicio	Fin	Días	1–15	16–31	1–15	16–30	1–15	16–31	1–15	16–30	1	2
1	F1	Redacción y consolidación del Capítulo II – Marco teórico	01-08	14-08	14										
2	F1	Revisión bibliográfica, citas y antecedentes	01-08	10-08	10										
3	F1	Formalización general del modelo ARDREC	15-08	24-08	10										
4	F1	Definición de variables, escalas y normalización	20-08	31-08	12										
5	F2	Formulación del riesgo estático inicial	25-08	05-09	12										
6	F2	Modelo de evidencia técnica y pesos beta	01-09	12-09	12										
7	F2	Modelo de criticidad y prioridad adaptativa	08-09	18-09	11										
8	F2	Función de riesgo final y criterios de parada	15-09	25-09	11										
9	F2	Diseño del análisis de sensibilidad y métricas	22-09	30-09	9										
10	F2	Pseudocódigo, máquina de estados y complejidad	26-09	05-10	10										
11	F3	Diseño de la arquitectura modular	01-10	08-10	8										
12	F3	Implementación del componente técnico en Rust	07-10	18-10	12										
13	F3	Implementación del componente analítico en Python	14-10	25-10	12										
14	F3	Integración JSON, TUI y generación de reportes	21-10	31-10	11										
15	F4	Configuración del laboratorio SSH, FTP y SMB	27-10	05-11	10										
16	F4	Construcción de rúbrica y 45 escenarios	30-10	08-11	10										
17	F4	Prueba piloto y ajuste controlado	06-11	10-11	5										
18	F4	Ejecución experimental emparejada	11-11	20-11	10										
19	F4	Análisis estadístico de resultados	18-11	25-11	8										
20	F4	Análisis de sensibilidad paramétrica	21-11	27-11	7										
21	F5	Redacción de resultados, discusión y prueba de hipótesis	24-11	30-11	7										
22	F5	Conclusiones, revisión formal y entrega final	29-11	02-12	4										

F1 Fundamentación • F2 Diseño algorítmico • F3 Desarrollo del prototipo • F4 Validación experimental • F5 Cierre documental

Fuente: elaboración propia con base en el Perfil de Tesis ARDREC (2026).

13. BIBLIOGRAFÍA

- Abu-Dabaseh, F., y Alshammari, E. (2018). Automated penetration testing: An overview. *Computer Science & Information Technology*, 8(6), 121–129. <https://doi.org/10.5121/csit.2018.80610>
- Alhamed, M., y Rahman, M. M. H. (2023). A systematic literature review on penetration testing in networks: Future research directions. *Applied Sciences*, 13(12), 6986. <https://doi.org/10.3390/app13126986>
- Alonso, D., y Antolínez, L. F. (2022). *Análisis de vulnerabilidades a un segmento de la red privada del área de TI de una empresa del sector industrial basado en la metodología PTES* [Trabajo de grado de especialización, Universidad Católica de Colombia].
- Barrios, A. G. (2024). *Análisis e implementación de las fases del pentesting detectando vulnerabilidades en un sistema informático remoto* [Tesis de ingeniería, Benemérita Universidad Autónoma de Puebla].
- Bass, L., Clements, P., y Kazman, R. (2012). *Software architecture in practice* (3rd ed.). Addison-Wesley.
- Behbehani, D., Komninos, N., Al-Begain, K., y Rajarajan, M. (2023). Cloud enterprise dynamic risk assessment (CEDRA): A dynamic risk assessment using dynamic Bayesian networks for cloud environment. *Journal of Cloud Computing*, 12, 79. <https://doi.org/10.1186/s13677-023-00454-2>
- Cachaya, H. A., Castañeda, H., Torres, L. E., y Pérez, J. J. (2025). Sandbox virtual con herramientas open source para pentesting: Una propuesta tecnológica aplicada a la seguridad cibernética de las PYMEs. *Sapiens in Artificial Intelligence*, 2(2), e-22001. <https://doi.org/10.71068/tgqmv81>
- Callisaya, Z. A. (2023). *Modelo de evaluación de seguridad para aplicaciones web basado en OWASP* [Tesis de maestría, Universidad Mayor de San Andrés].
- Chambi, L. I. (2024). *Modelo de gestión de seguridad para minimizar riesgos de seguridad informática en empresas del sector automotriz* [Tesis de maestría, Universidad Mayor de San Andrés].
- Cheimonidis, P., y Rantos, K. (2023). Dynamic risk assessment in cybersecurity: A systematic literature review. *Future Internet*, 15(10), 324. <https://doi.org/10.3390/fi15100324>
- Cheimonidis, P., y Rantos, K. (2025a). A novel proactive and dynamic cyber risk assessment methodology. *Computers & Security*, 154, 104439. <https://doi.org/10.1016/j.cose.2025.104439>

- Cheimonidis, P., y Rantos, K. (2025b). A proactive and time-sensitive cyber risk assessment model integrating Markov chains and Bayesian networks. *IEEE Access*, 13, 96911–96932. <https://doi.org/10.1109/ACCESS.2025.3575070>
- Chitraju, S. (2025). *The adaptive data-driven threat scoring for enhanced cybersecurity risk assessment* [Preprint]. SSRN. https://papers.ssrn.com/sol3/papers.cfm?abstract_id=5899422
- Conover, W. J. (1999). *Practical nonparametric statistics* (3rd ed.). John Wiley & Sons.
- Cormen, T. H., Leiserson, C. E., Rivest, R. L., y Stein, C. (2009). *Introduction to algorithms* (3rd ed.). MIT Press.
- Forum of Incident Response and Security Teams. (2024). *Common vulnerability scoring system version 4.0: Specification document*. Recuperado de: <https://www.first.org/cvss/v4-0/specification-document>
- Ghanem, M. C. (2022). *Towards an efficient automation of network penetration testing using model-based reinforcement learning* [Tesis doctoral, City, University of London]. <https://openaccess.city.ac.uk/id/eprint/29885/>
- Hance, J., Milbrath, J., Ross, N., y Straub, J. (2022). Distributed attack deployment capability for modern automated penetration testing. *Computers*, 11(3), 33. <https://doi.org/10.3390/computers11030033>
- Hevner, A. R., March, S. T., Park, J., y Ram, S. (2004). Design science in information systems research. *MIS Quarterly*, 28(1), 75–105. <https://doi.org/10.2307/25148625>
- Hung, N. V., y Cong, N. T. (2023). Applying reinforcement learning in automated penetration testing. *Journal of Science and Technology on Information Security*, 3(17), 61–77. <https://doi.org/10.54654/isj.v3i17.876>
- International Organization for Standardization/International Electrotechnical Commission. (2018). *Information technology — Security techniques — Information security risk management* (ISO/IEC 27005:2018). International Organization for Standardization.
- Islam, S., Basheer, N., Papastergiou, S., Ciampi, M., y Silvestri, S. (2025). Intelligent dynamic cybersecurity risk management framework with explainability and interpretability of AI models for enhancing security and resilience of digital infrastructure. *Journal of Reliable Intelligent Environments*, 11, 12. <https://doi.org/10.1007/s40860-025-00253-3>

- Jacobs, J., Romanosky, S., Edwards, B., Roytman, M., y Adjerid, I. (2019). *Exploit prediction scoring system (EPSS)*. 2019 Workshop on the Economics of Information Security. Recuperado de: <https://www.first.org/epss/research>
- Lazarov, W., Seda, P., Martinasek, Z., y Kummel, R. (2025). Penterep: Comprehensive penetration testing with adaptable interactive checklists. *Computers & Security*, 154, 104399. <https://doi.org/10.1016/j.cose.2025.104399>
- Luna, J. N. (2023). *Modelo de prevención de intrusos en la red con machine learning* [Tesis de grado, Universidad Mayor de San Andrés].
- Lutz, M. (2009). *Learning Python* (4th ed.). O'Reilly Media.
- Lyon, G. F. (2008). *Nmap network scanning: The official Nmap Project guide to network discovery and security scanning*. Insecure.Com LLC.
- Marsh, N. (2010). *Nmap cookbook: The fat-free guide to network scanning*. CreateSpace Independent Publishing Platform.
- McKinney, W. (2022). *Python for data analysis: Data wrangling with pandas, NumPy, and Jupyter* (3rd ed.). O'Reilly Media.
- Microsoft Corporation. (2026). *Server Message Block (SMB) protocol versions 2 and 3*. Microsoft Learn. Recuperado de: https://learn.microsoft.com/en-us/openspecs/windows_protocols/ms-smb2/5606ad47-5ee0-437a-817e-70c366052962
- Montgomery, D. C. (2004). *Diseño y análisis de experimentos* (2.^a ed.). Limusa Wiley.
- National Institute of Standards and Technology. (2008). *Technical guide to information security testing and assessment* (NIST Special Publication 800-115). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-115>
- National Institute of Standards and Technology. (2012). *Guide for conducting risk assessments* (NIST Special Publication 800-30 Revision 1). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-30r1>
- PCI Security Standards Council. (2017). *Penetration testing guidance: Information supplement* (Version 1.1). Recuperado de: https://www.pcisecuritystandards.org/documents/Penetration-Testing-Guidance-v1_1.pdf
- Phillips, S. C., Taylor, S., Boniface, M., Modafferi, S., y Surridge, M. (2024). Automated knowledge-based cybersecurity risk assessment of cyber-physical

- systems. *IEEE Access*, 12, 82482–82505.
<https://doi.org/10.1109/ACCESS.2024.3404264>
- Postel, J., y Reynolds, J. (1985). *File transfer protocol* (RFC 959). Internet Engineering Task Force. <https://doi.org/10.17487/RFC0959>
- Raza, H. (2024). *Systematic literature review of challenges and AI contributions in penetration testing* [Degree project, Luleå University of Technology].
- Renney, H., Chenchiah, I. V., Nethercott, M., Paligadu, R., y Lang, J. (2025). An open and adaptable approach to vulnerability risk scoring. *Journal of Cyber Security*, 7(1), 221–238. <https://doi.org/10.32604/jcs.2025.064958>
- Ridwan, R. (2024). Using the Penetration Testing Execution Standard Method (PTES) for wireless network security analysis. *Greenation Computer and Information Review*, 1(1), 25–32. <https://doi.org/10.38035/gcir.v1i1.336>
- Saltelli, A., Ratto, M., Andres, T., Campolongo, F., Cariboni, J., Gatelli, D., Saisana, M., y Tarantola, S. (2008). *Global sensitivity analysis: The primer*. John Wiley & Sons.
- Sierra, D. S., y Rincón, J. S. (2024). *Guía integral de ciberseguridad y pentesting para proteger activos digitales y detectar vulnerabilidades* [Proyecto de grado, Universidad Católica de Colombia].
- Skandylas, C., y Asplund, M. (2025). Automated penetration testing: Formalization and realization. *Computers & Security*, 155, 104454.
<https://doi.org/10.1016/j.cose.2025.104454>
- Sommerville, I. (2011). *Ingeniería de software* (9.^a ed.). Pearson Educación.
- Terpstra, J. H., y Vernooij, J. R. (Eds.). (2005). *The official Samba-3 HOWTO and reference guide* (2nd ed.). Prentice Hall.
- Triantaphyllou, E. (2000). *Multi-criteria decision making methods: A comparative study*. Springer.
- Walpole, R. E., Myers, R. H., Myers, S. L., y Ye, K. (2012). *Probabilidad y estadística para ingeniería y ciencias* (9.^a ed.). Pearson Educación.
- Ylönen, T., y Lonvick, C. (2006). *The Secure Shell (SSH) transport layer protocol* (RFC 4253). Internet Engineering Task Force. <https://doi.org/10.17487/RFC4253>

ANEXOS